

Internship Proposal

Student's Name : Thy Dayuth
Internship Position : IT Security
Project Title : Network Segmentation Effectiveness for PCI DSS Scope Reduction
Internship Start Date : 20 April 2026
Internship End Date : 20 July 2026

About Company

Overview

ACLEDA Bank Plc. is one of the largest and most trusted commercial banks in Cambodia. It was originally established in January 1993 as a non-governmental organization (NGO) that provided credit and development support to micro and small businesses. The institution later transformed into a specialized bank in 2000 and became a fully licensed commercial bank in 2003. Today, ACLEDA operates throughout Cambodia and has expanded its presence into Laos and Myanmar.

Vision

“To be Cambodia’s leading and the most trusted commercial bank serving all segments of the community.”

Mission

ACLEDA Bank's mission is to provide secure and innovative financial products and services that help customers manage their financial resources efficiently. The bank emphasizes ethical business practices, respect for society and the environment, and contributing to Cambodia’s socio-economic development.

Slogan

“The bank you can trust, the bank for the people.”

Main Services

ACLEDA Bank offers a wide range of banking and financial services, including:

- Savings and current accounts
- Fixed deposits
- Personal and business loans
- Debit and credit cards
- Mobile and internet banking
- Local and international fund transfers
- Trade finance services
- Cash management services
- Foreign exchange services
- Payroll and corporate banking solutions
- Securities and investment-related services through subsidiaries

Key Facts

- Founded: 1993
- Headquarters: Phnom Penh
- Licensed as a Specialized Bank: 2000
- Licensed as a Commercial Bank: 2003
- Listed on the Cambodia Securities Exchange in 2020
- Operates one of the largest banking branch networks in Cambodia
- First Cambodian bank to receive international ratings from agencies such as Standard & Poor's and GIIRS

Project Description

Network Segmentation Effectiveness for PCI DSS Scope Reduction

Organizations that process payment card transactions must comply with the Payment Card Industry Data Security Standard (PCI DSS) to protect cardholder data from unauthorized access and cyber threats. In many environments, payment systems share network resources with business departments and supporting services. This increases the number of systems that fall within PCI DSS scope, resulting in higher compliance costs, larger attack surfaces, and more complex security management.

This project focuses on evaluating the effectiveness of network segmentation as a method for reducing PCI DSS scope while maintaining strong security controls. The proposed design isolates the Cardholder Data Environment (CDE) from non-payment systems through the implementation of VLAN segmentation, firewalls, access control policies, a demilitarized zone (DMZ), and controlled administrative access. Only systems that process, store, or transmit cardholder data remain within the PCI DSS scope, while unrelated business systems are separated into out-of-scope network segments.

The project will design and simulate a segmented enterprise network consisting of a Retail Point of Sale (POS), DMZ server, application server, key management system (KMS), database server, jumpbox, and centralized logging infrastructure. Payment transactions will be transmitted through secured channels using TLS 1.2, processed within the isolated CDE, encrypted using AES-256, tokenized through the KMS, and securely stored in a PostgreSQL database. Centralized logging and monitoring will be implemented to support auditing and compliance validation.

The simulation will validate segmentation effectiveness through firewall rule verification, VLAN isolation testing, access control enforcement, and network scanning activities. Testing will demonstrate that unauthorized users and systems cannot directly access the CDE and that all communication paths follow approved security controls. The project will also assess how segmentation reduces the number of systems requiring PCI DSS compliance while strengthening overall security posture. The main objective of this project is to provide practical understanding of PCI DSS network architecture and demonstrate how effective segmentation can reduce compliance scope without compromising security. The project also serves as a hands-on learning platform for cybersecurity students and practitioners to gain experience in network security, access control, data protection, compliance validation, and secure payment system design.

Benefits of the Project

- Demonstrates the practical implementation of PCI DSS scope reduction through network segmentation.
- Provides hands-on experience in designing secure Cardholder Data Environments.
- Enhances understanding of VLAN segmentation, firewall security controls, and network isolation techniques.
- Demonstrates secure cardholder data processing using encryption, tokenization, and key management systems.
- Strengthens skills in security architecture design, compliance assessment, and access control implementation.
- Provides experience in validating segmentation effectiveness through testing and security auditing.
- Improves knowledge of centralized logging, monitoring, and compliance evidence collection.
- Serves as an educational platform for students and cybersecurity professionals interested in PCI DSS and enterprise security architecture.
- Establishes a foundation for future implementation of advanced security technologies such as SIEM, NAC, Zero Trust Architecture, and continuous compliance monitoring.

Methodology

The project will follow a structured methodology to design, implement, and validate a secure network architecture aligned with PCI DSS compliance standards. The methodology consists of distinct phases required to build the segmented infrastructure and evaluate its effectiveness in reducing the compliance audit scope.

Phase 1: Architecture Design and Requirement Analysis Activities

- Study PCI DSS compliance requirements specifically regarding network segmentation and scope reduction.
- Design the enterprise network topology defining the Cardholder Data Environment (CDE) and out-of-scope zones.
- Define hardware requirements, software tools, and cryptographic standards needed for the simulation.
- Outline the secure data processing flows covering data in transit and data at rest.

Deliverables

- Project requirements specification.
- Network topology and data flow diagrams.
- Literature review on segmentation effectiveness.

Phase 2: Core Network and Infrastructure Provisioning Activities

- Configure network switches to separate departmental virtual local area networks (VLANs) from the secure payment environment.

- Deploy perimeter and internal firewalls to establish the demilitarized zone (DMZ).
- Provision a centralized logging server to passively collect system telemetry.
- Deploy and harden an administrative jumpbox with a designated static IP address.

Deliverables

- Segmented baseline infrastructure.
- Operational jumpbox environment.
- Centralized log collection system.

Phase 3: Security Controls and Access Management Implementation Activities

- Implement Access Control Lists (ACLs) to enforce strict isolation between different department networks.
- Configure default deny policies on all firewalls to restrict unauthorized lateral movement.
- Enforce Multi-Factor Authentication (MFA) on the jumpbox to secure administrative pathways.
- Establish a secure TLS 1.2 tunnel bridging the retailer point of sale and the DMZ.

Deliverables

- Configured access control and firewall policies.
- Secured administrative access portals.
- Encrypted network transit pipelines.

Phase 4: Application Processing and Cryptography Integration Activities

- Initialize the PostgreSQL database with schemas designed to separate identity data from secure payment artifacts.
- Integrate a Key Management System (KMS) to perform AES-256 encryption and data tokenization.
- Develop the application server to process inbound traffic and restrict its outbound communication exclusively to the KMS and database.
- Develop a transaction payload generation script for the simulated retail point of sale.

Deliverables

- Operational data processing application server.
- Functional tokenization and cryptography engine.
- Secure transaction storage database.

Phase 5: End-to-End Validation and Segmentation Testing Activities

- Conduct network scanning to verify CDE isolation and prove the effectiveness of default deny rules.
- Simulate point of sale purchases to trace payload processing accurately through the DMZ and application server.
- Confirm the successful storage of tokenized and encrypted data within the database.
- Validate the centralized audit logs by reviewing dropped firewall packets and system access records.

Deliverables

- Network isolation verification records.
- Functional transaction simulation results.
- Audit log validation report.

Phase 6: Documentation and Reporting Activities

- Document technical implementation details and testing findings.
- Evaluate the overall reduction of the PCI DSS audit scope achieved through the deployed network architecture.
- Review lessons learned and recommend future security improvements.
- Compile the comprehensive final project report.

Deliverables

- Architecture validation documentation.
- Final Project Report.

Methodology Flow

1. Architecture Design and Requirement Analysis
2. Core Network and Infrastructure Provisioning
3. Security Controls and Access Management Implementation
4. Application Processing and Cryptography Integration
5. End-to-End Validation and Segmentation Testing
6. Documentation and Reporting

Approved by Supervisor

Approved by Advisor


MEAS SOTHEARATH
